

Data Privacy Impact Assessment (DPIA) — Face Vectors / Biometric Auto-Tagging

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted. · 2026-07-05

Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-01** (05_DPIA_Register_DRAFT_2026-07-05.md) — **HIGH-risk** because it processes **biometric data**, which is **sensitive personal information** under RA 10173 § 3(I). A full, dedicated assessment is warranted precisely because a face vector is not ordinary PII.

■ CORRECTION — verified against shipped code 2026-07-05 (read first)

This DPIA's **headline finding (BV-1 / §6) is SUPERSEDED**. It was drafted from the Privacy Policy §6.1's "implicit consent" wording — but that wording was **stale**. Verified in production code:

- app/[slug]/_components/selfie-capture.tsx — the face-recognition consent is an **explicit, separate checkbox** (name="biometric_consent", label "face recognition for this wedding"), **defaulted OFF** (useState(false)); un-checking it drops the selfie.
- app/[slug]/actions.ts (RSVP) **and** app/papic/face-enroll-actions.ts (day-of) both **refuse to create a face vector unless biometric_consent === '1'**, and stamp consent_at + consent_source on the enrolment (the evidenced record).

So the **explicit, separate, evidenced, default-OFF opt-in that §6 recommends is ALREADY SHIPPED** (owner directives 2026-06-05 / 2026-06-28). **BV-1 is substantially RESOLVED in production** → its residual is **Low**, not Med–High. The Privacy Policy §6.1 has been corrected to match (2026-07-05).

The genuinely open headline finding is now BV-8 — MINORS: guests carry no age/birth-date field, so nothing prevents a minor's face from being enrolled (a minor, or a guardian on their behalf, can tick the box). That is the live gap to close, and it is counsel-first. Read §6's recommendation as **"maintain + keep the policy accurate,"** not "implement."

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com · registered (or registration in progress [TO CONFIRM]) with the NPC
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Face vectors / biometric auto-tagging (Papic) — register R-01
Governing policy	01_Contracts/Setnayan_Privacy_and_Security_Policy.md § 1.4 (Face vectors), § 2.1 (auto-tag purpose), § 3.2 (media/vector storage), § 4 (retention), § 6.1 (photo/likeness consent)

Feature specs	0012_paparazzi/ (Papic capture → upload → tag) + 10_Papic_Feature_Specification.md
Risk level (inherent)	HIGH — biometric = sensitive personal information
DPIA status	DRAFT — pending DPO adoption + PH counsel review (counsel-first per register)
Version / date	2026-07-05

1. Description of the processing

1.1 What a face vector is

A **face vector** is a **128-dimension** numerical representation ("embedding") computed from a photograph of a person's face. It is not the photo itself — it is a mathematical fingerprint of the face's geometry that lets the system compare two faces for similarity. Under RA 10173 § 3(l), a template derived from a person's face for the purpose of identifying that person is **biometric data**, and biometric data is **sensitive personal information** (§ 3, and see § 12–13 for the heightened processing conditions that follow).

1.2 Why it is processed (purpose)

To **auto-tag guests in a specific event's photo gallery** (the Papic candid-capture service). When a paparazzo or another guest uploads a photo, the system compares faces in that photo against the enrolled guest vectors **for that event only**, and tags matches so each guest's tagged photos surface to them in their gallery and personal-reel builder (policy § 2.1: "Auto-tag photos via face matching (couple-scoped only)").

1.3 Data flow (capture → vector → match → tag → gallery)

1. **Capture / enrolment sources** (policy § 1.4) — a guest's face vector is enrolled from one or more of:
 - the guest's **RSVP profile photo**,
 - an **optional pre-event portal upload**,
 - the **on-the-day check-in kiosk**.
2. **Vector generation** — a 128-dim vector is computed from the enrolment image and written to a **per-event encrypted vector store** (policy § 3.2). The enrolment image itself is governed by the media rules in § 1.3/§ 3.2/§ 4.
3. **Per-event match at upload time** — when a photo/clip lands in the event gallery, detected faces are compared **only against that event's vector store**. Confidence thresholds:
 - **≥ 0.85** → **auto-tag** the guest,
 - **0.65–0.85** → surface a **suggested tag** for human confirmation,
 - **< 0.65** → the photo **uploads untagged** (still delivered — see § 5).
4. **Tag → gallery** — the resulting tag routes the photo into the matched guest's tagged-photos view; untagged photos still land in the couple's gallery (untagged-still-delivered guarantee).
5. **Revocation / expiry** — a guest "Delete my face data" link revokes enrolment within the **next 5-minute refresh cycle**; turning the **Photo Consent** toggle OFF revokes live enrolment and clears any selfie display photo; vectors are otherwise **deleted at the 5-year retention boundary** with the event data (policy § 4).

1.4 Data subjects

Guests (adults). Minors are excluded from the person-graph today; **whether child guests can be enrolled in face auto-tagging under the current build is [TO CONFIRM]** — this must be answered before adoption (see risk BV-8).

No vendor, couple, or admin faces are enrolled for auto-tagging.

1.5 Systems, storage, and retention

- **Vector store:** per-event, **encrypted at rest** (policy § 1.4, § 3.2, § 7.1 AES-256). Never reused across events/weddings.
- **Enrolment / gallery media:** Cloudflare **R2 (Asia-Pacific, APAC)**, signed-URL access only (policy § 3.2).
- **Matching engine host / location:** [TO CONFIRM] — the compute location and any sub-processor for the face-embedding/matching step is not recorded in the policy and must be confirmed (implicates § 10 cross-border analysis if it runs outside SG/PH).
- **Retention:** face vectors kept for the **per-event lifetime + 5 years**, then **auto-purged with the event data** (policy § 4). Earlier deletion via the guest "Delete my face data" link or Photo Consent OFF.
- **Database of record for tags/linkage:** Supabase Postgres (Singapore), RLS-gated (policy § 3.1).

2. Necessity & proportionality assessment

2.1 Is biometric auto-tagging *necessary* for the purpose?

The purpose — getting each guest their own photos out of a large shared event gallery — is legitimate and central to Paptic. Face auto-tagging makes that **convenient and complete at scale**, but it is **not the only means** of achieving it.

Less-intrusive alternatives already exist in the product:

- **Manual tagging** — the couple / guests tag photos by hand.
- **QR tagging** — the paparazzo scans a guest's personal QR (`setnayan:guest:{id}`) or a table QR (`setnayan:table:{id}`) to tag, with table-tag fan-out to seated guests (capped at 10 tags/photo). This is a first-class, already-shipped tagging path in the Paptic spec that requires **no biometric processing at all**.

Because QR and manual tagging deliver the same core outcome without processing sensitive biometric data, face auto-tagging is best characterized as a **convenience/coverage enhancement layered on top of non-biometric tagging**, not a strict necessity. This framing matters for the consent standard (§ 6): a non-essential, sensitive-data feature should be **separately opt-in**, and a guest who declines it should still get full non-biometric service.

2.2 Proportionality — is biometric justified given the alternatives, and is it minimized?

On balance the biometric layer can be **proportionate**, *conditional on the consent fix in § 6*, because the design already minimizes it structurally:

- **Per-event scoping** — vectors are **never reused across events/weddings**; the store is siloed per wedding, so there is no cross-event identification capability and no growing biometric identity graph.
- **Thresholds tuned to reduce harm** — ≥ 0.85 to auto-tag, a human-in-the-loop **suggested-tag** band (0.65–0.85), and **< 0.65 uploads untagged** rather than guessing.
- **Untagged-still-delivered** — the feature is not load-bearing for photo delivery; a face that never matches still reaches the couple's gallery, so declining biometrics costs the guest nothing structural.
- **Purpose-limited** — vectors are used **only** to tag within the one event; policy § 2.3 forbids sale, cross-vendor sharing, and out-of-platform advertising.
- **Revocable + time-boxed** — "Delete my face data" (≤ 5 -min revocation), Photo Consent OFF, and the 5-year hard deletion.

Conclusion. The processing can be proportionate **only if** (a) the feature stays a genuine opt-in overlay on non-biometric tagging (which it is), and (b) the **consent standard is upgraded to explicit, separate, evidenced opt-in for face recognition** (§ 6). Absent (b), the sensitive-data processing is **not adequately justified** against the available less-intrusive alternatives.

3. Consultation

- **DPO:** this DPIA is prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The headline consent-standard question (§ 6) and the open [TO CONFIRM] items (minor enrolment; matching-engine location) are referred to the DPO and PH counsel for confirmation.
- **Data subjects (guests):** consulted at the point of processing via the RSVP/portal/kiosk consent surfaces and the in-profile **Photo Consent** toggle. **This DPIA finds the current guest-facing consent moment insufficient for biometric data** and recommends a dedicated, separate face-recognition opt-in string (§ 6) — the consultation mechanism exists but its content must be upgraded.
- **External counsel / NPC:** **required** before wider rollout (register R-01 is "counsel-first"). Counsel to confirm the § 6 consent standard, the minor-enrolment position, and whether an NPC consultation is advisable given the biometric + event-guest population.

4. Risk assessment table (biometric-specific)

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§ 5). Biometric processing starts HIGH by default.

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
BV-1	Processing sensitive biometric data without a valid consent standard — "implicit consent" from an RSVP photo upload may not meet the RA 10173 § 3(b)/§ 12–13 bar of <i>freely given, specific, informed, and evidenced</i> consent for sensitive data (see § 6, KEY FINDING)	High	High	High	Opt-in framing + Photo Consent OFF toggle + untagged-still-delivered (declining costs nothing)	Med–High — NOT resolved by current controls. Reduces to Low only after an explicit, separate, evidenced face-recognition opt-in is added (§ 6). Headline gap.

BV-2	Function creep / cross-event identification — vectors reused to identify a person across weddings, building a biometric identity graph	Med	High	High	Per-event scoping — vectors NEVER reused across events (policy § 1.4). No cross-event vector store; person-graph schema has no face field (DPIA 05 PG-6)	Low
BV-3	Vector breach or theft — biometric templates exfiltrated; a face cannot be reset like a password	Med	High	High	Encrypted at rest (AES-256, policy § 1.4/§ 7.1); per-event silo limits blast radius; signed-URL-only media; RLS; 72-hr NPC + user breach notice (§ 8)	Low–Med — residual impact stays elevated because biometrics are irrevocable; [TO CONFIRM] whether vectors are separately key-scoped per event and whether raw enrolment images are purged post-vectorization
BV-4	Misidentification / wrong-tag harm — a guest tagged in a photo that isn't them (or vice-versa), causing embarrassment or mis-delivery	Med	Med	Med	Threshold ladder (≥ 0.85 auto · 0.65–0.85 human-confirmed suggestion · < 0.65 untagged); couple review window before public unlock; max 10 tags/photo	Low

BV-5	Inability to withdraw / exercise erasure — a guest cannot effectively revoke enrolment	Med	High	Med–High	"Delete my face data" link ($\leq$ 5-min revocation); Photo Consent OFF revokes live enrolment + clears selfie; account-deletion cascade to face vectors (policy § 4)	Low
BV-6	Covert or non-consensual capture (paparazzi) — a guest photographed/enrolled without a real choice	Med	High	Med–High	Paparazzi opt-out with face-blur for opted-out guests (policy § 6.1); NSFW filter always-on	Low–Med — depends on the § 6 consent fix and on opt-out being surfaced <i>before</i> capture, not only after [TO CONFIRM]
BV-7	Re-identification from vectors — a stored 128-dim template reverse-engineered or matched against an external face database	Low	High	Med	Per-event silo (no cross-event corpus to link against); encryption at rest; no sale/sharing (§ 2.3); no external face DB used	Low
BV-8	Child / minor faces enrolled — a minor guest's biometric processed without lawful guardian consent	[TO CONFIRM]	High	High	Minors excluded from person-graph; whether the auto-tag enrolment path itself blocks minors is [TO CONFIRM]	[TO CONFIRM] — cannot be rated Low until minor-enrolment behavior is confirmed and, if enrolment is possible, blocked or guardian-consent-gated
BV-9	Retention beyond necessity — vectors kept longer than needed for tagging	Low	Med	Med	5-year hard deletion with event data; earlier deletion via link/toggle; auto-purge (policy § 4)	Low

5. Controls already built

The following controls exist in the shipped design and are load-bearing for the residual ratings above:

- **Opt-in enrolment + Photo Consent OFF toggle** — enrolment originates from a guest-supplied RSVP/portal/kiosk photo; the profile **Photo Consent** toggle turns face detection off at any time (policy § 6.1). *(Note: this DPIA finds the opt-in standard itself insufficient for sensitive data — see § 6.)*
- **Per-event scoping — vectors NEVER reused across events (policy § 1.4)** — the single most important control against function creep and cross-event identification.
- **Confidence thresholds** — ≥ 0.85 auto-tag · $0.65\text{--}0.85$ human-confirmed suggestion · < 0.65 untagged.
- **"Delete my face data" link + ≤ 5 -minute revocation cycle**, and Photo Consent OFF revokes live enrolment + clears any selfie display photo.
- **5-year deletion** — vectors auto-purge with event data at the retention boundary (policy § 4); account-deletion cascades to face vectors (§ 4).
- **Face-blur for paparazzi opt-outs** — opted-out guests are face-blurred in captures (policy § 6.1).
- **Encryption at rest** — per-event vector store encrypted (AES-256), signed-URL-only media, RLS-gated linkage tables (policy § 1.4/§ 3.1/§ 3.2/§ 7.1).
- **NSFW filter always-on** and **couple review window** before public unlock (per Papic constraints).
- **Untagged-still-delivered guarantee** — declining biometrics never blocks a guest's photos from reaching the gallery.

6. KEY FINDING — the consent standard for biometric data (headline)

Finding. RA 10173 treats biometric data as **sensitive personal information**, and its processing requires consent that is **freely given, specific, informed, and EVIDENCED** (§ 3(b) defines consent; § 13 governs sensitive personal information; § 12 governs the general lawful bases). The current design relies on **"implicit consent"** — a guest uploads an RSVP profile photo and that upload is treated as consent to face-recognition auto-tagging (policy § 6.1: *"implicit consent — they uploaded the photo for this purpose"*).

Assessment. For **ordinary** PII, an implied/purpose-bundled consent may be defensible. For **sensitive biometric** data it is **likely insufficient**, for three reasons:

1. **Not specific.** Uploading a photo is a distinct act from consenting to have a **biometric template** computed and matched. Bundling the two means the biometric consent is not *specific* to that processing.
2. **Not clearly informed.** The guest is not necessarily told, at the moment of upload, that a 128-dim face vector will be generated, stored per-event, and used to auto-tag them.
3. **Not clearly evidenced.** "They uploaded a photo" is weak, contestable evidence of consent to biometric processing; RA 10173 expects consent to sensitive processing to be demonstrable as a discrete, recorded choice.

Recommendation (conservative path — the headline recommendation of this DPIA). Introduce an **explicit, separate, granular opt-in for face recognition**, distinct from photo upload:

- A dedicated toggle/consent string — e.g. *"Use face recognition to automatically find and tag me in this event's photos"* — presented **separately** from uploading a profile photo, defaulted **OFF**, and **logged with timestamp** (mirroring the `policy_acceptances` evidence pattern, ideally a purpose-specific `face_recognition_consent` record [TO CONFIRM]).
- Uploading a photo (for a display avatar / manual use) must remain possible **without** enabling face recognition — the two choices decoupled.
- Keep the full non-biometric path (QR + manual tagging) as the default so declining face recognition is costless.

- Re-consent, don't grandfather: existing enrolments captured under the implicit-consent model should be re-papared under the explicit opt-in before wider rollout [TO CONFIRM] with counsel.

Adopt this **unless PH counsel advises** that a narrower approach satisfies § 12–13 for this population. This is the single change that most reduces the residual risk of the whole feature (BV-1).

7. Residual-risk conclusion

With the controls in § 5 — above all **per-event scoping**, the **threshold ladder**, **≤ 5-min revocation**, **5-year deletion**, **face-blur opt-out**, and **encryption at rest** — most biometric risks reduce to **Low** (BV-2, BV-4, BV-5, BV-7, BV-9) or **Low–Med** (BV-3, BV-6).

However, overall residual risk is **CONDITIONAL** and cannot be declared **Low–Medium** until the **consent-standard fix lands**. Specifically, before or at wider rollout / scale:

1. **MUST — upgrade the consent standard (BV-1 / § 6)**: ship an **explicit, separate, evidenced face-recognition opt-in**, decoupled from photo upload, defaulted OFF, and logged. Re-consent existing enrolments. *This is the gating item.*
2. **MUST — resolve minor enrolment (BV-8)**: confirm whether the auto-tag path can enrol a minor guest today; if so, block it or gate it behind verified guardian consent. [TO CONFIRM]
3. **SHOULD — confirm engine location + key/image hygiene (BV-3)**: record the matching-engine host/location (and any sub-processor / cross-border transfer per policy § 10), confirm per-event key scoping, and confirm raw enrolment images are purged after the vector is derived. [TO CONFIRM]
4. **SHOULD — ensure paparazzi opt-out is offered before capture (BV-6)**, not only remediated after.

With items 1–2 done, residual risk across the feature is **Low–Medium**. Until then, the biometric processing should be treated as **counsel-first / not-cleared-for-wider-rollout**, consistent with the register R-01 status.

8. Sign-off

Role	Name	Signature	Date
Data Protection Officer	Indalecio Sacdalan Casasola II	_____	[TO CONFIRM date]
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	_____	[TO CONFIRM date]

Next review date: [TO CONFIRM date] (recommend: on adoption of the explicit face-recognition consent flow, at any material change to the vector schema / thresholds / retention, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The biometric processing remains counsel-first (register R-01): the explicit-consent upgrade (§ 6) and the minor-enrolment question (BV-8) must be resolved before wider rollout.